IT 系統管理

多系統帳號、權限與資產關聯管理系統

以 Ragic 建立人員、帳號、群組、NAS 權限、設備與維護資源的集中管理架構

陳家榮｜IT維運與系統管理

PORTFOLIO　RAGIC　ISO 27001 導向

核心價值

可追溯　・　可交接　・　可盤點　・　可稽核

問題不是「沒有清冊」，而是資料彼此沒有關係

01 帳號分散

AD、三台 NAS、MailCloud 各自管理，命名與狀態標準不一致。

對應做法 以獨立的系統帳號清冊 ACC 統一記錄各平台帳號，區分個人、共用、管理員與儀器帳號。

02 離職風險

人員離職時，難以一次確認所有帳號、群組與資料夾權限。

對應做法 人員頁彙總持有帳號與所屬群組，NAS 權限一條規則一筆紀錄，可逐筆確認回收。

03 交接困難

系統、承載設備、維護廠商與窗口資訊分散，仰賴個人記憶。

對應做法 系統主檔串接設備、廠商與聯絡窗口，異常或交接時可直接找到負責對象。

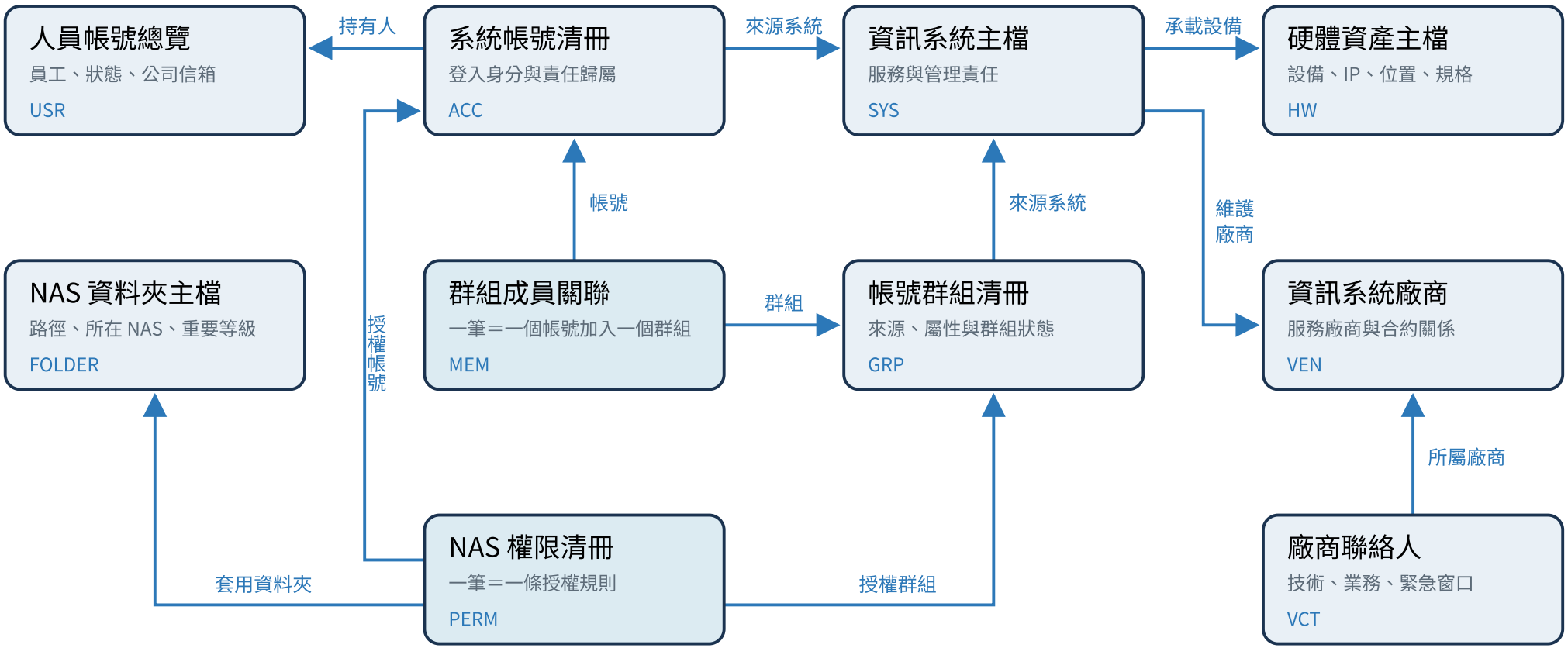
實際成效 系統已上線，用於日常帳號管理，並已據此完成 AD 與三台 NAS 的首次全面盤點（見第 11 頁）。人員到職或離職時，開啟該人員頁面即可一次看到跨 5 個系統的持有帳號、所屬群組與資料夾權限，依清單逐項處理，異動時不再遺漏。

建置目標

- 以人員為核心，彙總跨系統持有帳號與主要公司信箱
- 將 NAS 資料夾與權限規則拆分，保留一條規則一筆紀錄
- 保留狀態、責任人、盤點日期與來源，形成 ISMS 稽核證據
- 以獨立帳號主檔管理個人、共用、管理員與儀器帳號
- 串接系統、硬體、廠商與聯絡窗口，支援維護與交接

03 十張表單的整體關聯架構

連結欄位指向被引用的主檔，主檔再以子表反向彙總



箭頭的意義

連結欄位 → 被引用的主檔

與《ISMS 與帳號權限管理整合實例》採相同畫法：例如 ACC 的「所屬人員」指向 USR，MEM 同時指向 ACC 與 GRP。主檔再以子表反向彙總，因此仍可從人員一路查到帳號、群組、資料夾權限、系統、設備與廠商。MEM 以「ACC｜GRP」作唯一關聯鍵，讓一個帳號可加入多個群組，同一群組也可包含多個帳號；FOLDER 另以「所在 NAS」連結 SYS，圖中省略以保持清晰。

資訊系統主檔

系統編號	系統名稱	系統類別	系統環境	系統狀態	主機名稱	驗證來源	IT主要負責人姓名
SYS-000	MailCloud－公司郵件服務	電子郵件／通訊服務	正式	使用中		系統本機	
SYS-000	NAS- 備份儲存服務	備份與儲存	正式	使用中		Active Directory 系統本機	
SYS-000	NAS- 主要檔案服務	檔案儲存	正式	使用中		Active Directory 系統本機	
SYS-000	NAS- 檔案服務	檔案儲存	正式	使用中		Active Directory 系統本機	
SYS-000	NAS- 檔案服務	檔案儲存	正式	使用中		系統本機	
SYS-000	Active Directory	身分與帳號管理	正式	使用中		Active Directory	

計算所有資料加總

資訊系統主檔｜系統清單（實際畫面，主機名稱與負責人已遮蔽）

連結設計

SYS → HW	資訊系統主檔的承載設備子表	一項系統可連結主機、備援機或虛擬機；設備主檔保留 IP、位置與規格。
SYS → VEN	資訊系統的維護廠商欄位	系統異常或合約交接時，可直接找到服務提供者。
VCT → VEN	廠商聯絡人的所屬廠商	同一廠商可有多位技術、業務或緊急聯絡窗口。

05 人員、帳號與所屬群組彙總

人員頁同時呈現持有帳號，以及各帳號所屬的群組關係

持有系統帳號

帳號編號	系統名稱	登入帳號	帳號狀態	帳號類型	帳號驗證來源	是否為特權帳號	本帳號隨人員離職停權	最後登入日期	歸屬確認狀態
ACC-00249	Activ ory		啟用	個人帳號	Active Directory	✓	✓	1150806	已確認
ACC-00464	NA 服務		啟用	個人帳號	系統本機	✓	✓		已確認
ACC-00667	NA 服務		啟用	個人帳號	系統本機	✓	✓		已確認
ACC-00695	NA 服務		啟用	管理員帳號	系統本機	✓	✓		已確認
ACC-00721	NA 檔案服務		啟用	個人帳號	系統本機	✓	✓		已確認
ACC-00778	MailCloud		啟用	個人帳號	系統本機	✓	✓		已確認

人員明細｜第一個子表：持有系統帳號（局部放大，登入帳號與系統代號已遮蔽）

所屬帳號群組

成員關聯編號	帳號系統名稱	帳號編號	登入帳號	群組編號	群組名稱	成員狀態	帳號狀態	系統一致性	最後確認日期
MEM-0	Active Directory	ACC-00		GRP-0	Domain Users	有效	啟用	一致	1150820
MEM-0	Active Directory	ACC-00		GRP-0		有效	啟用	一致	1150820
MEM-0	Active Directory	ACC-00		GRP-0		有效	啟用	一致	1150820

人員明細｜第二個子表：所屬帳號群組，由 MEM 帶回（編號與群組名稱已遮蔽）

人員主檔
姓名、部門、人員狀態
USR

→ 1 對多

系統帳號
AD、NAS、MailCloud 身分
ACC

→ 1 對多

成員關聯
ACC｜GRP 唯一關聯鍵
MEM

→ 多對 1

帳號群組
來源系統與群組名稱
GRP

帳號連結人員後，人員頁的第一個子表反向彙總全部 ACC；MEM 再把每個 ACC 的群組成員關係帶回人員頁。共用或服務帳號不必假造人員，只需保留責任單位與維護人。子表中的「是否為特權帳號」「隨人員離職停權」欄位，讓離職時可一次確認須處理的帳號。



NAS 權限清冊｜單筆授權規則（路徑與帳號資訊已遮蔽）

一條規則一筆紀錄

資料物件	記錄內容
資料夾 FOLDER	完整路徑、所在 NAS、重要等級
權限規則 PERM	讀寫／唯讀／自訂／拒絕
授權對象	帳號 ACC 或群組 GRP，或系統內建對象
最終歸屬	經 ACC 帶出權限所屬人員 USR

一個資料夾可有多條規則；每條規則只對應一個授權對象。**拒絕權限必須獨立保存**，避免被讀寫權限覆蓋。

everyone、owner 等系統內建對象不連結 ACC／GRP，另以「系統內建對象」標記；非標準權限組合記為「自訂」。本表記錄權限狀態，不取代 NAS 實際 ACL 設定。



帳號群組成員關聯表

記錄系統帳號與帳號群組之間的成員關係，一筆資料代表一個帳號加入一個群組，並保留資料來源、有效狀態、確認日期及移除紀錄。本表用於呈現人員的群組歸屬，不直接變更 AD 或 NAS 權限。

成員基本資料

成員關聯編號		成員狀態	有效
帳號編號		登入帳號	
帳號系統名稱	Active Directory	帳號狀態	已停用
帳號驗證來源	Active Directory	帳號類型	個人帳號
權限所屬人員		員工編號	
人員狀態	離職	使用部門	
人員關聯			

所屬群組資料

群組編號		群組名稱	
群組系統名稱	Active Directory	群組來源類型	Active Directory
系統一致性	一致		

MEM 明細｜帳號、群組與一致性（編號與群組名稱已遮蔽）

三種狀態各自獨立

狀態	描述的對象	範例
人員狀態	人是否在職	離職
帳號狀態	ACC 是否啟用	已停用
成員狀態	這條群組關係是否有效	有效

以左圖這筆紀錄為例：人員已離職、帳號已停用，但群組成員關係仍標為有效。三種狀態分開記錄，盤點時才看得出哪些群組關係需要清理。

「系統一致性」比較 ACC 與 GRP 的來源系統編號，協助攔截跨系統誤連。

08 Ragic 連結與自動帶出設計

連結欄位負責選對主檔；載入欄位負責顯示主檔資訊

表單	主連結欄位	連結目標	自動帶出	用途
人員總覽	主要郵件帳號	系統帳號 ACC	公司信箱／帳號狀態	以帳號主檔為單一來源
系統帳號	權限所屬人員	人員 USR	姓名／部門／人員狀態	建立帳號責任歸屬
NAS 權限	NAS 資料夾	資料夾 FOLDER	系統名稱／完整路徑	確認權限套用位置
NAS 權限	使用帳號／授權群組	ACC／GRP	登入名／驗證來源／狀態	確認授權對象
群組成員	成員帳號	系統帳號 ACC	登入名／姓名／部門	顯示群組成員資訊
成員關聯	所屬群組	帳號群組 GRP	群組名／來源系統編號	建立 ACC × GRP 關係
資訊系統	承載設備	硬體資產 HW	IP／資產狀態／角色	建立系統承載關係

避免失效的設定原則

① 先建立主連結，再設定自動帶出　② 連結鍵優先使用穩定編號（USR／ACC／SYS／FOLDER），不要用姓名
③ 匯入更新時，第一欄必須是可比對的 Key　④ 改動連結後需重新儲存或批次更新舊資料，既有載入值不一定自行回填
⑤ 新增與更新分成不同匯入檔：有對應的空白欄位會覆蓋既有資料　⑥ 匯入前先備份，並以少量資料試匯確認欄位對應

09 帳號生命週期與 ISMS 稽核應用

把表單資料轉成可執行、可證明的管理流程

01 申請
建立人員與需求
責任人／申請日期

02 建立
系統帳號建檔
帳號類型／驗證來源

03 授權
群組與 NAS 權限
最小權限／核准紀錄

04 盤點
定期核對狀態
盤點日期／異常註記

05 異動
部門或職務變更
權限調整／覆核

06 離職
停權與移除成員
停用日期／完成證據

可形成的稽核證據

身分與責任
帳號對應人員、責任單位及系統來源

存取控制
群組成員、NAS 權限層級與拒絕規則

資產關係
資訊系統、承載設備、IP 與維護廠商

生命週期
申請、啟用、停權、刪除與最近盤點日期

持續改善
異常帳號、孤兒帳號、離職未停權與複核結果

帳號安全屬性
特權、共用、MFA、密碼不過期與變更日期

對應 ISO/IEC 27001:2022 附錄 A：A.5.9 資產清冊、A.5.16 身分管理、A.5.18 存取權限、A.8.2 特權存取權限、A.8.3 資訊存取限制。僅為設計對照，不代表已通過驗證。

下一階段預計增加的功能

01 Microsoft 365 帳號

納入 Exchange、Teams、OneDrive，並管理群組與授權方案。

02 人資異動申請

到職、轉調、留停與離職由人資發起，通知 IT 辦理。

03 權限調整報表

由人員帳號產生應新增、應移除與待確認的權限清單。**平台與清冊的差異比對已完成初版。**

04 通知與稽核軌跡

保留申請、核准、執行、覆核日期與處理人，逾期自動提醒。

跨部門權限異動流程

人資提出申請
人員／異動原因／生效日
STEP 1

→

主管確認
職務需求與權限範圍
STEP 2

→

IT 執行調整
帳號、群組、NAS、M365
STEP 3

→

完成與覆核
覆核人不兼執行人，保存證據
STEP 4

分階段導入規劃

Phase 1｜帳號範圍

建立 Microsoft 365 系統主檔、帳號類型、授權方案與群組關聯。

Phase 2｜流程串接

新增人資申請單、主管核准、IT 工作清單與完成通知。

Phase 3｜自動化治理

產生權限差異報表、逾期提醒、定期覆核與稽核儀表板。差異比對工具已先完成（第 11 頁）。

原則：系統仍不保存密碼或 Token；若未來串接 API，憑證應置於專用秘密管理工具。

11 首次全面盤點與自動化比對

把一次性的人工比對，變成每次都能重跑的檢查

4 個平台
AD 與三台 NAS，各自以腳本或管理介面匯出

500+ 帳號
逐筆比對啟用狀態、持有人與同步鍵

900+ 關聯
帳號與群組的成員關係，含特權群組

6 類異常
回平台修正並更新清冊，過程寫成結案紀錄

盤點流程

平台匯出 — PowerShell／SSH 腳本／DSM，只讀取不修改 — STEP 1

→

差異比對 — 本機瀏覽器執行，資料不離開電腦 — STEP 2

→

先修平台 — 高風險項目回 AD／NAS 處理 — STEP 3

→

分檔匯入 — 帳號新增／狀態／成員新增／成員移除 — STEP 4

→

重跑確認 — 差異歸零，截圖留存為稽核證據 — STEP 5

盤點發現的異常類型

- 離職人員帳號未停用
- 停用帳號仍在特權群組
- 清冊與實際狀態不符
- 平台帳號未登錄清冊
- 同一帳號重複建檔
- 帳號連結到錯誤人員

經驗回寫到維護手冊，成為下次盤點的檢查項目。

比對工具的防呆設計

- 自動辨識檔案種類與來源主機，放錯檔案即提示
- 只有確定是同一人時才自動連結人員，避免誤連擴散
- 主要群組、套件服務帳號等平台特性不誤判為差異

盤點心得

差異大多來自「同一個人在不同平台各有一份身分」。工具能縮短比對時間，但根本解法是收斂身分來源：規劃讓仍使用本機帳號的 NAS 加入網域，逐步改由 AD 統一管理。

比對工具：需求、比對規則與驗收由本人負責，程式由 AI（Claude）協作產出。數量為概數。